CloudDesk Technologies

Vendor Risk Management Policy

1. Authority, purpose and scope

SYNTHETIC / DEMO - document control

CD-VRM-001 | Version 1.0 | Fictional effective date: 2026-10-22 | Next review: 2027-10-22. Engineering Lead owns this policy; CTO is accountable for adoption and material residual risk. Review annually and after material changes or incidents. Editable UTF-8 JSON is the source of truth for this PDF. Approval_status: not_recorded; review_status: requires_user_review.

Status and adoption limits

CloudDesk Technologies is a fictional 75-person B2B SaaS company. This model-authored Policy 8 of 8 contains proposed SYNTHETIC / DEMO requirements, not operating facts. No actual vendors, completed assessments, certifications, SOC 2 reports, ISO certification, DPA or legal compliance, implemented monitoring or audit evidence are asserted. Human content review and recorded CTO approval are required before adoption.

Purpose and supplier scope

Manage confidentiality, integrity, availability and privacy risks across acquisition, onboarding, use, change and exit. Cover processors/subprocessors, SaaS and cloud vendors, contractors, outsourced support and critical dependencies, including identity, KMS, DNS, storage and recovery services where applicable. Include trials, free services and integrations before scoped information or access is enabled. A purchasing route or low price does not remove security review.

Ownership and related authority

Assign a business owner and system owner for each vendor; no staffed procurement, privacy or legal department is assumed. Owners document purpose, dependencies and risk and coordinate contracts with qualified advice as needed. Engineering Lead reviews assessments and tracks findings; CTO accepts material residual risk. All seven related policies retain authority for identity, encryption, security governance, incidents, recovery, changes and personnel. Record unresolved conflicts for Engineering Lead and CTO resolution before adoption; vendor approval grants no new decrypt, destructive or communication authority.

Vendor Risk Management Policy

2. Vendor inventory and risk tiering

Inventory and accountable ownership

Before onboarding, record a vendor ID, proposed legal entity/service, business owner, system owner, purpose, engagement dates and renewal/exit conditions. Map information classes, customer data categories, processing purposes, access privileges, interfaces, storage/processing/support locations, subprocessors and upstream dependencies. Track contract and assessment versions, risk tier and rationale, findings, approvals, review dates, exit plan and evidence limitations. Update on material change and retirement; this sample supplies no actual vendor inventory.

Risk tiering dimensions

Assess customer data sensitivity and volume, processor/subprocessor role, administrative or persistent access, service criticality, resilience and recoverability, geography/jurisdiction, cross-border processing, concentration and substitutability. Consider common cloud, identity, region or fourth-party failure paths across vendors. Record inherent risk, verified safeguards and residual risk separately; missing information is uncertainty requiring review, not evidence of low risk.

Proposed tiers and escalation

Treat as high risk vendors with privileged production access, sensitive customer data processing, or a critical dependency whose failure could cause material harm. Critical vendors are those essential to service or recovery; flag criticality separately from tier so annual reassessment is not lost. Moderate risk covers bounded nonprivileged access to nonpublic information without high-risk characteristics. Low risk requires documented limited exposure and low impact. Engineering Lead reviews tier rationale; use the higher applicable tier when dimensions conflict and escalate unresolved uncertainty to CTO.

Reassessment and risk register

Reassess critical vendors annually and reassess affected vendors after material changes or incidents, including new subprocessors, ownership, regions, data use, privileges, assurance gaps or resilience concerns. Owners track renewal conditions and arrange review before changed use. Engineering Lead coordinates at least annual security risk assessments and quarterly open-risk reviews under CD-ISP-001. Record findings, remediation owners, due dates and CTO acceptance decisions; overdue material risks require escalation rather than silent renewal.

Vendor Risk Management Policy

3. Pre-onboarding due diligence and agreements

Security and privacy due diligence before use

Before onboarding or enabling scoped access, owners document data flows, minimization, purpose, access needs and shared responsibility. Engineering Lead reviews risk-appropriate security and privacy due diligence: identity controls, tenant isolation, encryption, vulnerabilities, incident handling, logging availability, resilience, deletion, locations and subcontractors. Review privacy terms and processor/subprocessor obligations with qualified advice where applicable. Assess lawful processing and transfer needs case by case; a signed DPA alone does not establish legal compliance.

Appropriate evidence and assurance gaps

Request proportionate evidence such as security questionnaires, architecture explanations, relevant policies, independent assessment summaries if available, scoped technical validation and recovery/deletion descriptions. Verify evidence date, scope, service coverage, exclusions, provenance and remediation status; record unavailable or unverified claims. No vendor certification is assumed or universally required; a SOC 2 report or ISO certificate alone would not establish suitability. Limit copies of confidential reports and do not request plaintext secrets or unnecessary personal data.

Contract security and incident terms

Before scoped use, review agreements addressing confidentiality, permitted data use and restrictions on secondary use, security responsibilities, approved access, incident cooperation and breach/incident reporting based on applicable contract and law. Specify triggers, recipients, timing basis and updates appropriate to the engagement; there is no universal notification deadline. Address data return/deletion, retained backups and holds, subcontractor controls/change notice, assurance rights, service changes and exit assistance. Record unresolved terms and obtain appropriate advice; no executed contract is supplied.

Approval gate for high-risk use

Engineering Lead reviews assessment scope, evidence limitations, proposed safeguards and unresolved findings before high-risk use. CTO acceptance of material residual risk is required before use; record decision maker, date, scope, conditions, owner and reassessment triggers. Missing material evidence or unresolved unacceptable risk blocks planned onboarding or changed use until mitigated or explicitly accepted through authorized governance. Purchasing approval or a vendor sales claim is not security approval. Route planned deviations through bounded exceptions; do not mark assessments complete without supporting review records.

Vendor Risk Management Policy

4. Integration, access and company-side safeguards

Onboarding identity and access

Apply approved onboarding under CD-HRS-001 and access control: use unique user accounts and multi-factor authentication for administrative access. Document sponsor, role, start/end dates, system-owner approval and least privilege before provision. Review user access permissions every quarter, including vendor workforce, dormant identities and sponsor validity. Restrict service identities and OAuth/API scopes to approved functions; protect secrets and record grants. Training and confidentiality arrangements follow personnel governance without assuming vendor employees share company employment screening rules.

Encryption and shared responsibility

Company-side requirements remain TLS 1.2 or TLS 1.3 for scoped transport, AES-256 at rest for scoped production storage and backups, and managed KMS for production keys under CD-ENC-001. Assess vendor controls against applicable data flows and these requirements; do not blindly assign company KMS architecture or every company control to all vendors. Document responsibility boundaries, evidence, gaps and required contractual safeguards; escalate deviations through encryption governance. Public marketing storage follows existing scope; administrative and authentication traffic still need protection.

Integration changes and key boundaries

Assess integrations, regions, subprocessors, data flows and permission changes before enabling changed access; scoped technical changes follow CD-CHG-001 with testing, approval and rollback/recovery planning. Engineering Lead approves key grants; key administrators have no default decrypt permission. Preserve quarterly grant reviews, symmetric key-encryption key rotation at least every 12 months and restricted older versions for dependent retained data/backups and holds. Destruction requires Engineering Lead and CTO approval after retention and recovery checks; vendor exit never authorizes blind key destruction.

Continuous monitoring proposals

Owners propose risk-based ongoing oversight of vendor advisories, service/security changes, incident notices, assurance expiry, unresolved findings, access changes and concentration indicators. Define sources, review cadence, responsible substitutes and escalation conditions proportionately before adoption. No existing monitoring tool, staffed service, continuous telemetry coverage or completed monitoring is asserted. Track observations and uncertainty with verified contacts; monitoring supplements annual critical-vendor reassessment and event-triggered review, and does not prove absence of compromise.

Vendor Risk Management Policy

5. Incidents, resilience and fourth parties

Vendor incident escalation and notification

Promptly report suspected vendor exposure, unauthorized access or disruption to Engineering Lead through verified proposed internal routes; use CTO or a designated alternate if unavailable. Link vendor notices and affected services to an incident record under CD-IRP-001, preserve evidence and reassess severity as facts change. Responders may take urgent reversible containment action; do not delay immediate containment for routine approvals. CTO authorizes material shutdowns, residual-risk decisions and external communications with appropriate advice. Assess notification duties case by case under contract/law without waiting for perfect investigation if earlier notice is required.

Backup and recovery dependencies - targets TBD

Map vendor availability, exports, identity, region, KMS/key versions, support and fourth-party dependencies into recovery plans. RTO, RPO, backup frequency and retention remain TBD pending BIA/business and contractual review under CD-BDR-001; vendor advertised targets do not establish CloudDesk recovery capability or an agreed SLA. Validate data consistency, authorized recovery access and tenant boundaries; replication alone is not proof of recoverable backup. Reconcile deletion commitments, retained copies and holds with qualified advice where needed.

Quarterly restores and annual continuity exercises

Preserve a representative encrypted restore at least quarterly, recording integrity, authorized key access and outcome, with risk-based dependency coverage. Exercise continuity scenarios at least annually and after material changes, including vendor outage, inaccessible exports, common-region failure and unavailable responders. An annual continuity tabletop does not replace a representative quarterly encrypted restore; a restore does not by itself establish broader continuity readiness. Record limitations and remediation; no completed restore or exercise is asserted.

Fourth parties and concentration exposure

Owners identify material subprocessors and fourth parties, roles, data/location changes and shared upstream dependencies to the extent discoverable. Review available flow-down obligations, change notice/objection processes and evidence access; record opaque chains as risk. Assess correlated failures across cloud, identity, network, support and geographic dependencies, substitution cost and lock-in. Seek proportionate alternatives or compensating safeguards with Engineering Lead review and CTO acceptance of material residual risk. A vendor remains accountable under its agreement; CloudDesk retains its own review and incident responsibilities.

Vendor Risk Management Policy

6. Exit, records, exceptions and adoption

Vendor offboarding and portability

Before critical use, plan exit triggers, alternative providers or manual options, export formats, ownership, migration sequence, dependency validation, cost and contract assistance. Test portability proportionately using authorized minimized or synthetic data; no successful migration is asserted. At termination, expiry or scope reduction, coordinate timely removal aligned to the effective end and risk; revoke vendor accounts, sessions, tokens, OAuth grants and integrations, transfer ownership and verify completion. Preserve the employee rule to revoke access within 24 hours of termination; it is not a universal vendor waiting period. Urgent compromise requires immediate containment.

Data return, deletion and restricted records

Verify data return, usable exports and agreed deletion evidence, including subcontractors, retained backups and hold limitations; record gaps and accountable follow-up rather than declaring deletion from a request alone. Do not destroy keys needed by retained data or recovery. Keep proposed inventory, assessments, evidence provenance, contracts, approvals, access reviews, incidents, reassessments, exit checks and exception records restricted with version history. Retention is set through approved business/contractual/legal review and holds. The minimum 12-month retention for KMS audit logs only is not a universal vendor-record retention rule. No actual audit artifacts are supplied.

Bounded exceptions and emergency deviations

Before planned deviation, owner records requirement, scope, rationale, risk, compensating safeguards, remediation owner and expiry. Engineering Lead assesses; CTO approves or rejects. Exceptions expire within 90 days and are reviewed monthly; renewal requires fresh assessment and approval. Expired approval cannot authorize use. Emergency deviations require a linked incident and next-business-day CTO review; do not delay urgent containment. Exceptions cannot erase applicable obligations or silently extend employee termination limits; encryption and destructive key authority remains unchanged. No active exception is asserted.

Annual review and human adoption gate

Engineering Lead reviews this policy annually and after material changes or incidents. Human reviewers must validate tier criteria, inventory coverage, contract/privacy advice, evidence sufficiency, staffing/substitutes, reporting routes, monitoring proposals, recovery dependencies and feasible exits against all seven related policies. Record conflicts, feedback and CTO approval before adoption. Approval_status: not_recorded; review_status: requires_user_review. Passing extraction, deterministic rebuild and lexical retrieval checks is not human semantic approval, an actual vendor assessment, certification or proof of control effectiveness.